TECHNICAL DETAIL

Title	Stored Cross-Site Scripting (XSS) via Server-Side Validation Bypass
Reporter	Daffa Rahadya Atmawiguna
Date	2025-12-28
Affected Asset	https://bertani.my.id/forum
Severity	**Medium**
CVSS Score	**5.4** **CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:L/A:N**
Proof of Concepts	Please see Steps to Reproduce section

SUMMARY

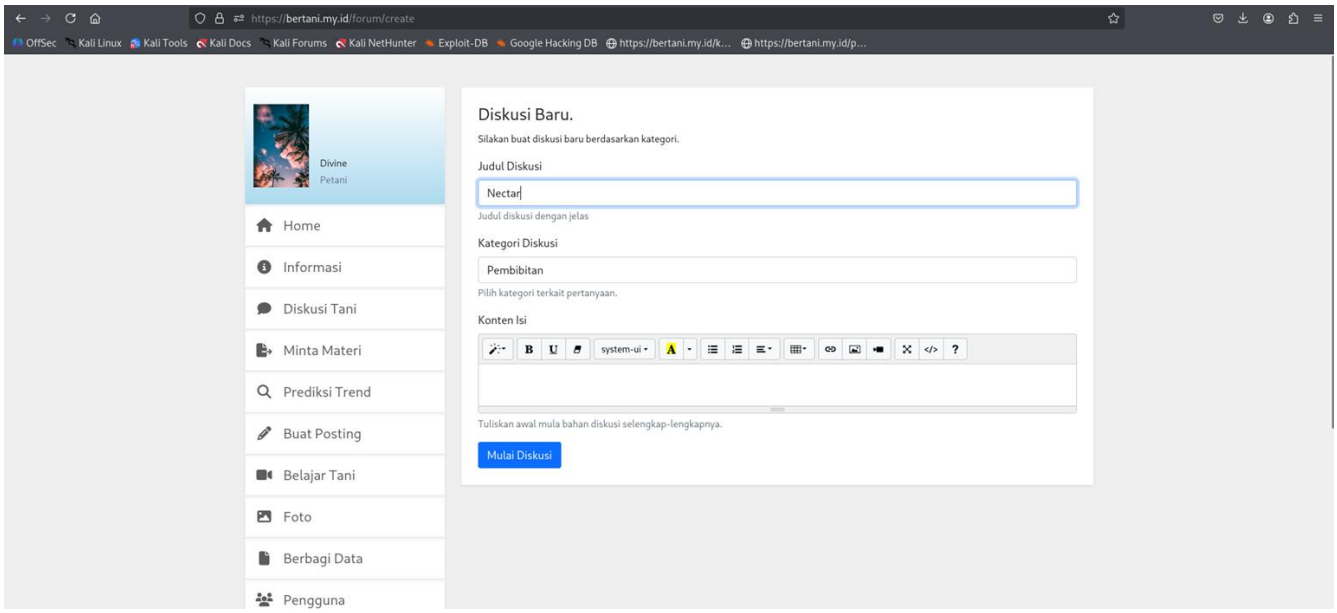
Terdapat celah keamanan Stored Cross-Site Scripting (XSS) pada fitur Forum Diskusi di URL https://bertani.my.id/forum. Kerentanan ini terjadi karena aplikasi tidak melakukan validasi atau output encoding yang memadai di sisi server pada parameter thread_content. Meskipun aplikasi mungkin membatasi input di sisi antarmuka (Front-end), pembatasan tersebut dapat dilewati dengan memanipulasi permintaan menggunakan Burp Suite. Akibatnya, payload JavaScript yang disuntikkan akan tersimpan di database dan dieksekusi secara otomatis di browser pengguna lain (korban) saat mereka membuka halaman Forum.

STEPS TO REPRODUCE

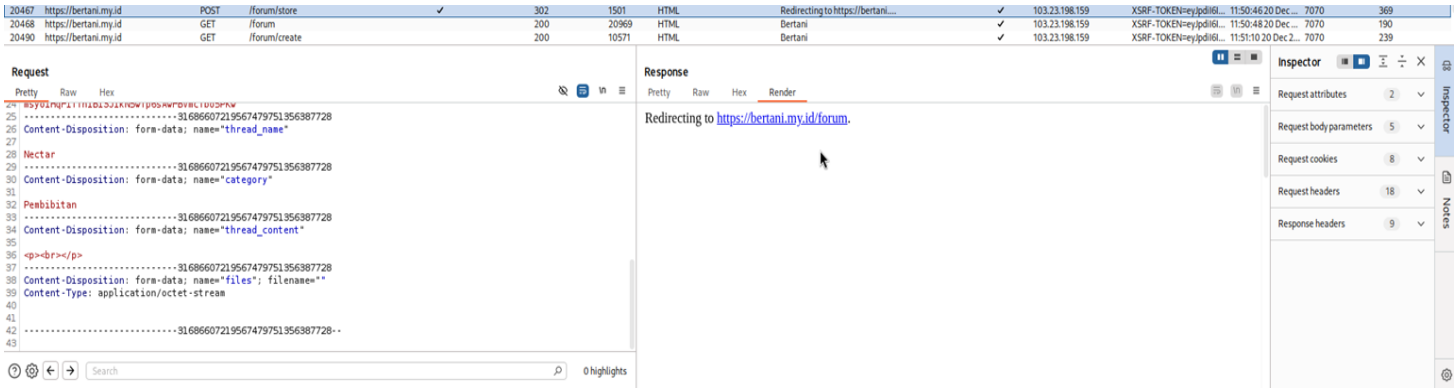
1. Login ke akun anda sebagai user di URL https://bertani.my.id/login

2. Siapkan Burp Suite dan aktifkan Proxy pada browser.

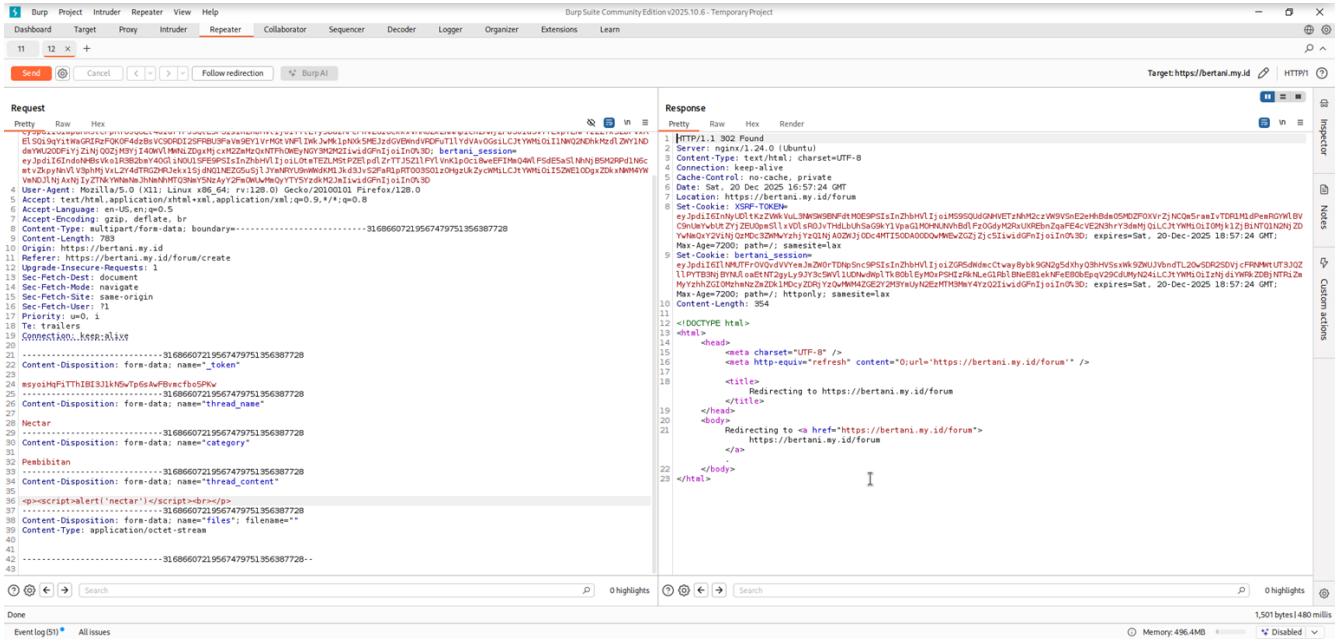
3. Buka halaman https://bertani.my.id/forum/create untuk buat diskusi baru , isi formulir sembarang, lalu klik "Mulai Diskusi".



4. Intercept permintaan POST /forum/store di Burp Suite dan kirim ke Repeater.



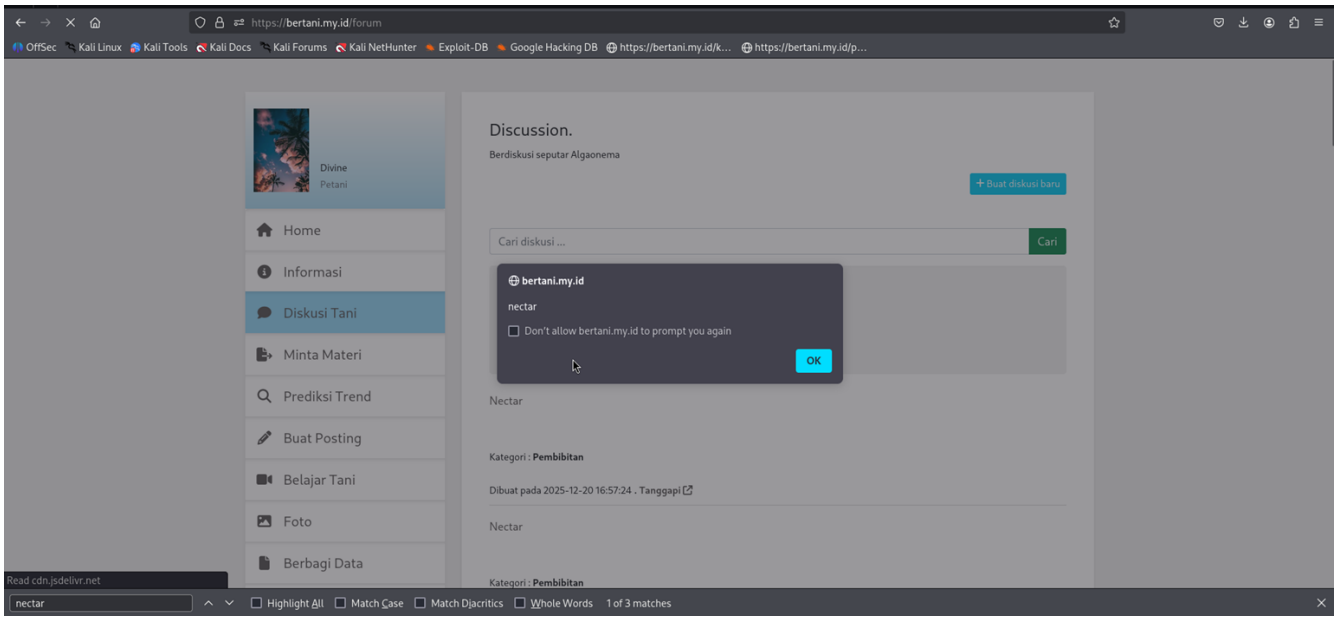
5. Pada tab Repeater, modifikasi parameter thread_content dengan menyisipkan payload XSS. yaitu: <script>alert('nectar')</script>



6. Klik "Send" untuk mengirim permintaan yang sudah dimodifikasi ke server.

7. Kembali ke browser dan buka halaman utama forum: https://bertani.my.id/forum

8. Hasil: Payload berhasil dieksekusi dan memunculkan *pop-up alert*.



EXPECTED RESULT

Saat pengguna lain mengunjungi halaman https://bertani.my.id/forum, payload tersebut seharusnya ditampilkan sebagai teks biasa dan tidak dieksekusi sebagai kode program.

ACTUAL RESULT

Saat pengguna lain mengunjungi https://bertani.my.id/forum, payload JavaScript tereksekusi secara otomatis dan memunculkan jendela peringatan (alert).

IMPACT

1. Pencurian Data: Penyerang dapat mencuri *cookie* sesi pengguna lain untuk mengambil alih akun.

2. Redirect: Mengarahkan pengguna secara paksa ke situs berbahaya.

RECOMMENDATION

Jangan hanya mengandalkan sanitasi di sisi *client* (browser) karena validasi tersebut sangat mudah dilewati menggunakan alat *proxy* seperti Burp Suite. Developer wajib melakukan pembersihan input (*sanitization*) kembali di sisi server menggunakan *library* yang terpercaya untuk menghapus tag HTML berbahaya sebelum data disimpan ke dalam database.

REFERENCES

1. **OWASP Cross Site Scripting (XSS): https://owasp.org/www-community/attacks/xss/**
2. **OWASP XSS Prevention Cheat Sheet: https://cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html**